BRACKENMOOR NHS FOUNDATION TRUST

SOC EMAIL HEADER FORENSICS TASK

The Golden Invoice: Sender Authentication & Mail Path Investigation

1. Scenario

It is Monday at 09:18. Brackenmoor NHS Foundation Trust's Accounts Payable coordinator reports a suspicious invoice email to the Digital Security team. The message appears to come from an external invoicing provider and claims that invoice INV-33421 is overdue. The message pressures the recipient to review the invoice within 24 hours and contains a "View Invoice" link.

This is an invoice-themed phishing message using the fictional sender identity "PayHub Invoicing". The sender's domain is payhub-notify-secure.com, while the Reply-To address redirects replies to a free Gmail mailbox. The investigation must determine whether the email is genuinely associated with the claimed invoicing organisation or is an impersonation attempt.

The source case study records SPF fail, DKIM none, DMARC permerror, origin IP 203.0.113.77, and the defanged link domain invoice-review[.]link. The complete Received chain and gateway headers below are a simulated training extension created specifically for this exercise.

2. Email Under Investigation

From	"PayHub Invoicing" <no-reply@payhub-notify-secure.com>
Reply-To	Billing Support <payhub.billingsupp0rt@gmail.com>
To	accounts.payable@brackenmoor.nhs.uk
Subject	Invoice INV-33421 Shared With You - Payment Overdue, Action Required
Date	Mon, 25 Aug 2026 09:16:42 +0100
Message-ID	<INV-33421-88217@payhub-notify-secure.com>

3. Header Evidence

```
Received: from mail.payhub-notify-secure.com (mail.payhub-notify-secure.com [203.0.113.77]) by
outbound01.payhub-notify-secure.com with ESMTP id GINV01; Mon, 25 Aug 2026 08:14:31 +0000

Received: from outbound01.payhub-notify-secure.com (198.51.100.42) by mx01.brackenmoor.nhs.uk with
ESMTPS id BMNHS88217; Mon, 25 Aug 2026 09:16:39 +0100

Received: from mx01.brackenmoor.nhs.uk (10.24.8.15) by mailstore01.brackenmoor.nhs.uk with ESMTP id
STORE88217; Mon, 25 Aug 2026 09:16:41 +0100

Authentication-Results: mx01.brackenmoor.nhs.uk; spf=fail smtp.mailfrom=payhub-notify-secure.com;
dkim=none; dmarc=permerror header.from=payhub-notify-secure.com

X-Trust-Mail-Gateway-Auth: unauthenticated-external

X-Trust-Mail-Gateway-Source: mx01.brackenmoor.nhs.uk
```

```
Return-Path: <no-reply@payhub-notify-secure.com>

X-Mailer: InvoiceMailer/2.4
```

4. Analyst Task

You are the Tier 1 SOC analyst assigned to the alert. Analyse the evidence without opening the phishing link from a production workstation. Determine the true origin, authentication status, mail path, sender legitimacy, and indicators that support or contradict the claimed invoicing identity.

1. Originating IP Address

What is the originating IP address? List every IP address in the Received headers and arrange them in the order the email passed through the infrastructure. For each public IP, state what can reasonably be inferred. Note that 203.0.113.77 and 198.51.100.42 are documentation-range addresses used for training.

2. SPF, DKIM and DMARC

What do SPF fail, DKIM none and DMARC permerror indicate about the authenticity of the sending domain? Explain each result.

3. Received Header Analysis

How many mail-handling servers did the email pass through before reaching the recipient? List them in order and identify anomalies or unusual patterns that support a spoofing or impersonation hypothesis.

4. Sender Identity

Who is the sender according to the From header? Does the sending domain align with the claimed invoicing organisation? Compare the From, Return-Path, Message-ID domain and Reply-To.

5. Mail Gateway Authentication Headers

The original Microsoft-specific X-MS-Exchange-Organization questions have been replaced because this scenario is not a Microsoft account notification. Analyse X-Trust-Mail-Gateway-Auth and X-Trust-Mail-Gateway-Source. What do they suggest about sender authentication?

6. Invoice Theme and Legitimacy

The subject is “Invoice INV-33421 Shared With You - Payment Overdue, Action Required.” Based on the sender, Reply-To, authentication results and mail path, is this legitimate or phishing? Justify your conclusion.

7. Reply-To Investigation

Does payhub.billingsupp0rt@gmail.com align with the claimed PayHub identity? Identify the typo-like “supp0rt” construction and explain why a free Gmail Reply-To is a red flag.

8. IOC Extraction

Extract the sending domain, origin IP, Reply-To domain/address, link domain and other suspicious artefacts. Defang domains and URLs.

9. MITRE ATT&CK Mapping

Which MITRE ATT&CK technique applies to the Golden Invoice scenario, and why is T1566.002 Spearphishing Link appropriate?

10. Final Verdict and Escalation

Provide a final verdict of Benign, Suspicious, or Confirmed Phishing. State the evidence supporting your decision and recommend immediate SOC containment actions.

5. Expected Analyst Outputs

- Received-header table with each hop in order
- SPF, DKIM and DMARC interpretation
- From versus Reply-To comparison
- Defanged IOC list
- MITRE ATT&CK mapping
- Defensible phishing verdict
- Recommended containment and response plan

6. Analyst Safety Rules

- Do not open invoice-review[.]link from a production device.
- Preserve the original email and headers before modifying evidence.
- Use a sandbox or isolated environment for URL inspection.
- Do not reply to the attacker-controlled Gmail address.
- Treat the documentation-range IP addresses as simulated training values.

7. Source and Training Note

This document is based on the Brackenmoor NHS Foundation Trust Golden Invoice case study. The case study provides the sender, Reply-To, subject, SPF/DKIM/DMARC findings, origin IP, IOC set and T1566.002 mapping. The Received chain and X-Trust gateway headers are explicitly simulated additions for practical analyst training.